MS-CyNum
TP Network Access Control (NAC)
AAA, Radius, 802.1x, EAP

INSA-Lyon
Département Télécom
Walid Bechkit

1 Introduction

Une partie de ce TP est inspirée des travaux pratiques proposés dans [1,2,3]. Par ailleurs, le livre "Authentification Réseau avec Radius" de Serge Bordères [4] constitue une très bonne référence pour approfondir différentes notions traitées dans le cadre de ce TP.

Sans perte de généralité, ce TP se fera sous des machines Linux Ubuntu et des Routeurs et Switch Cisco. Commencez par vous connecter en root sur les stations Linux (login : root ; pwd : linadm).

2 Architecture de travail et installation du serveur Radius "freeradius"

Dans un premier temps, mettez en place un réseau local 192.168.0.0/24 entre deux stations et un routeur. L'interface du routeur aura l'adresse IP 192.168.0.1, celle de la première station (client) 192.168.0.2 et celle de la deuxième station(serveur Radius) 192.168.0.3. Sur votre Switch, branchez tous les cables sur les ports 1-12 pour que vos interfaces soient toutes dans le VLAN 1. Testez la connectivité IP entre les deux stations et le routeur.

Même si nous utiliserons à la fin une seule machine comme serveur radius (192.168.0.3), l'installation et la configuration du serveur radius (Sections 2 et 3) peut être faite sur les deux machines pour que tous les étudiants puissent prendre en main freeradius.

Commencez par installer freeradius avec la commande :

sudo apt-get install freeradius

En consultant le help de la commande freeradius, trouvez les options qui vous permettent de vérifier que freeradius est bien installé tout en affichant les informations de debug.

3 Configuration du serveur Radius "freeradius"

FreeRadius dispose de plusieurs fichiers de configuration pour décrire son environnement. Ces fichiers se trouvent dans le répertoire /etc/freeradius/ (ou /etc/freeradius/3.0/ selon votre installation). Commencez par consulter ce dossier. Consultez le fichier dictionary pour se familiariser avec la notion d'attributs.

Les trois fichiers les plus importants que nous allons étudier dans ce TP sont : clients.conf, radiusd.conf et users.

3.1 fichier de configuration clients.conf

Ce fichier contient les informations sur les clients (NAS) et sur le secret qu'ils doivent partager avec le serveur radius. Ce fichier peut contenir plusieurs entrées suivant la forme :

```
client <short-name> {
        <attribute> = <value>
}
```

Les attributs les plus importants sont "ipaddr" (ou "ipv6addr" en IPv6), "secret", "shortname" et "nastype". L'attribut "secret" correspond à un secret partagé entre les clients et le serveur NAS et il est utilisé pour sécuriser la communication entre le serveur et ses clients (authentification de messages RADIUS et chiffrement de quelques attributs). Dans les versions 1.x, la chaîne après le mot client était l'adresse IP du client. Dans les versions 2.x, l'adresse IP est configurée via les champs ipaddr ou ipv6addr. Pour des raisons de compatibilité, le format 1.x est toujours accepté dans les versions 2.x.

Un simple exemple est donné dans le fichier suivant. Sauvegardez l'ancien fichier dans clients.conf.orig et mettez à jour votre fichier clients.conf.

```
client 192.168.0.0/24 {
        secret = monsecret
}
```

3.2 Fichier de configuration radiusd.conf

Ce fichier de configuration contient les modules, les options et les paramètres du serveur radius. En résumé, radiusd.conf est composé des sections suivantes :

- Paramètres du service Radiusd : cette section contient la déclaration des chemins d'accès et des ports d'écoute ainsi que l'inclusion du fichier clients.conf vu ci-dessus.
- Section de déclaration des modules : cette section contient la déclaration des modules nécessaires au fonctionnement.
- Section Instantiate : section facultative qui sert à pré-charger quelques modules.
- Section **Authorize** : Contient les modules qui doivent être exécutés pour préparer des tables intermédiaires nécessaires à la phase d'authentification. Ces tables contiennent d'un coté les valeurs des attributs envoyés par les requêtes d'authentification et d'un autre coté les informations récupérées des bases de données d'authentification.
- Section **Authenticate** : contient la liste des modules qui seront exécutés par le serveur pour l'authentification. Cette section pourra rester vide s'il s'agit de vérification simple de mot de passe.
- Section **PreAcct** : contient la liste de modules appelés avant l'accounting (traçabilité/comptabilité)

— Section **Accounting** : contient la liste de modules qui gèrent l'accounting (traçabilité/comptabilité)
— Section Session : contient la liste de modules qui gèrent les sessions simultanées ;
— Section Post-Auth : contient les actions à lancer après l'authentification ;
— Section Pre-Proxy : contient les modules appelés avant le "proxying" d'un paquet
— Section Post-Proxy : contient les modules appelés lorsque la réponse arrive du proxy.

En consultant la fin du fichier **"radiusd.conf"**, trouvez le fichier qui contient la définition des sections "Authorize", "Authenticate", "Accounting", etc.

A partir de maintenant, nous travaillerons seulement avec le fichier **"defalut"** sans modifier **radiusd.conf**. Seuls quatre sections vont nous intéresser durant ce TP : **Authorize, Authorize, Preacct et Accounting**. Il est à noter que les deux modules que nous utiliserons pendant ce TP sont :

- **preprocess** : ce module analyse la requête issue du NAS afin de remplir les attributs "request" ;

- **files** : ce module permet d'utiliser une base de données d'authentification sous forme de fichier local. Il consulte ce fichier local et remplit les attributs de "contrôle" et de "réponse" sur cette base ;

- Les modules **pap**, **chap** et **mschap** gèrent des méthodes d'authentification que nous discuterons durant ce TP. Lorsque cités dans la section "authorize", ils cherchent les attributs associés à la méthode d'authentification et ils positionnent l'attribut "Auth-Type". Lorsque cités dans la section "authenticate", ils exécutent la méthode d'authentification associée ;

- Le module **eap** gère le protocole EAP qui est un protocole de transport des messages d'authentification (voir cours). Lorsque cité dans la section "authorize", il cherche les attributs EAP-Message dans la requete il positionne l'attribut "Auth-Type := EAP". Lorsque cité dans la section "authenticate", il exécute la procédure d'authentification de la méthode qu'il embarque.

Avant de le modifier, copiez-le dans un autre fichier **"default.orig"**. Remplacer ensuite le contenu du fichier default par la configuration minimale suivante :

```
authorize {
preprocess
files
pap
chap
eap
}

authenticate {
Auth-Type PAP {
                pap
                }
Auth-Type CHAP {
                chap
                }
Auth-Type EAP {
                eap
                }
}

preacct {
}
accounting {
}
session {
}
post-auth {
}
pre-proxy {
}
post-proxy {
}
```

3.3 fichier de configuration users

Le fichiers users est le fichier d'authentification local utilisé par le module "files" pour l'authentification et l'autorisation. Ce fichier est constitué de rubriques qui correspondent à des conditions. le DEFAULT correspond à toute valeur de « User-Name ». La ligne Fall-Through = 1 permet de continuer l'analyse des rubriques suivantes.

```
DEFAULT
        Tunnel-Type = VLAN,
        Fall-Through = 1


DEFAULT Nas-Port == 10, Nas-IP-Address == 192.168.0.2
        Idle-Timeout = 600,
        Fall-Through = 1

walid Cleartext-Password := "test"
        Tunnel-Private-Group-Id = 4

francois Cleartext-Password := "test123"
        Tunnel-Private-Group-Id = 5
```

Expliquez les quatre rubriques ci-dessous. Sauvegardez ensuite votre fichier dans users.orig et remplacez le par un fichier similaire à celui donné dans l'exemple ci-dessus (vous pouvez modifier et/ou ajouter des rubriques).

4 Premiers tests d'authentification Radius (station Linux comme client NAS)

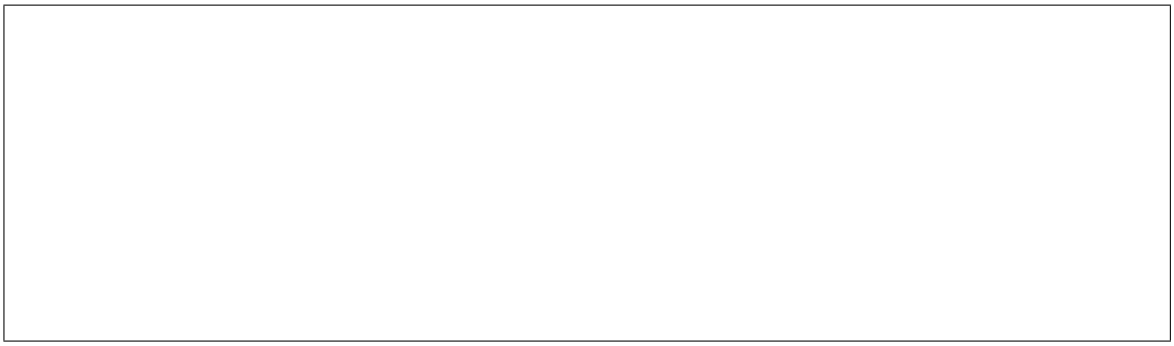
Commencez cette étape par lancer Wireshark sur la station client (192.168.0.2) et sur le serveur radius (192.168.0.3).

Lacez maintenant le serveur radius (commande freeradius) sur la station ayant l'interface 192.168.0.3. Attention, il est nécessaire d'arrêter le service freeradius avant si il en cours d'exécution (sudo service freeradius stop). Une manière plus "agressive" serait d'arrêter tous les pororcessus écoutant sur le port 1812 par exemple (kill -9 $(lsof -t -i :1812)). Aussi choisissez la bonne option pour voir les informations de Debug.
Du coté client, la commande Radtest est une simple commande qui permet de tester le serveur radius en l'interrogeant. En regardant son manuel et les informations affichées sur le serveur, construisez la bonne commande et testez votre serveur radius. Analysez à la fois les résultats affichés et les paquets échangés capturés par Wireshark

Cette étape est importante, prenez le temps nécessaire pour tester des secrets valables / non valables, des utilisateurs valables / non valables, des mots de passe valables / non valables, etc. Changez aussi le fichier users afin de multiplier vos tests.



Testez les trois méthodes d'authentification PAP, CHAP et EAP-MD5. Analysez les paquets capturés à chaque fois.



Si vous souhaitez approfondir vos connaissances autour des méthodes d'authentification avec freeradius, vous pouvez consulter le chapitre 5 du guide freeradius disponible en ligne [5].

5 Authentification 802.1X et affectation dynamique à des Vlan

Dans cette partie, vous allez mettre en place une authentification 802.1X et des autorisations associées (affectations automatiques à des VLANs). Commencez par vous Connecter au Switch de votre demi-banc.

5.1 Configuration du switch comme client NAS et contrôleur 802.1X

Sur le Switch, affichez les différents VLANs déjà configurés (commande "show vlan"), notez les et notez les interfaces sur lesquelles les stations client et serveur sont branchées (vous pouvez utiliser la commande show mac address-table).

Configurez esnuite l'adresse IP du VLAN 1 de telle sorte qu'elle soit dans le même réseau IP du serveur Radius. Testez la connectivité dans votre réseau local.

Créez maintenant deux autres VLAN ayant les identifiants 4 et 5 (commande "vlan id-vlan").



1.1 Activez le modèle d'authentification AAA sur le Switch.

Switch(config) aaa new-model

1.2 Créez un profil d'authentification 802.1X par défaut.

Switch(config) aaa authentication dot1x default group radius

1.3 Créez un profil d'autorisation par défaut.

Switch(config) aaa authorization network default group radius

1.4 Activez l'authentification 802.1X sur le switch.

Switch(config) dot1x system-auth-control

Au niveau de l'interface qu'on souhaite contrôler (port du Switch auquel le client est connecté)
2.1 Positionnez le port en mode Access.

Switch(config-int) switchport mode access

2.2 Activez la fonctionnalité 802.1X sur l'interface.

Switch(config-int) dot1x pae authenticator

2.3 Conditionnez l'accès au port à une authentification 802.1X.

Switch(config-int) authentication port-control auto

3. En utilisant la commande radius-server, configurez les paramètres de votre serveur Radius (IP du host, ports et secret partagé). Ici les ports doivent être les ports par défaut confirgrés sur le serveur radius : auth-port 1812 et acct-port 1813.

Switch(config) radius-server ...

Vous pouvez confirmer le bon fonctionnement entre votre client radius (switch à ce niveau) et le serveur radius avec la commande.

Switch test aaa group radius <user> <password> port <port-nas> new-code

Débranchez et rebranchez le cable de la satation "Client" sur le Switch. Arrivez-vous au ping d'autres stations du réseau local ? Expliquez.

5.2 Configuration d'un client Supplicant et test de l'authentification

Sur la station "client", créer un fichier de configuration et remplissez le avec les clauses suivantes :

```
ctrl_interface=/var/run/wpa_supplicant
ctrl_interface_group=0
eapol_version=2
ap_scan=0

network={
        key_mgmt=IEEE8021X
        eap=MD5
        identity= "francois"
        password= "test123"
        eapol_flags=0
}
```

Lancez maintenant la commande wpa-supplicant et observez les paquets échangés ainsi que les messages affichées sur les terminaux.

wpa_supplicant -c <fichier-de-config> -D wired -i ethx

N'hésitez pas à débrancher / rebrancher le câble et à essayer plusieurs utilisateurs. Analysez à chaque fois les paquets échangés et les messages affichés.

5.3 Affectation automatique des VLAN (A comme Authorization)

Sur le switch créez les VLANs auxquels vous souhaitez affecter les utilisateurs.

Sur le serveur Radius, positionnez dans le fichier user les attributs suivants pour tous vos utilisateurs (vous pouvez utiliser DEFAULT pour les attributs communs) :

Tunnel-Type = vlan
Tunnel-Medium-Type = IEEE-802
Tunnel-Private-Group-Id = X

Débrancher le câble de station client et rebranchez le. Affichez vos Vlans sur le Switchs. Commentez.

6 Protocole AAA avec un Routeur comme client NAS (BONUS)

A partir de maintenant, nous utiliserons le routeur comme client NAS. Lancez Wireshark sur le serveur radius.

Essayez de vous connecter au routeur en telnet à partir de la station 192.168.0.2. La connection fonctionne-elle correctement ?

Sur le routeur, accédez à la configuration des lignes VTY 0 à 4 et et activez le mode d'authentification locale. Faites attention, il ne faudrait pas se tromper de type de ligne, seuls les lignes VTY sont utilisées pour contrôler les connexions Telnet. .

```
Router(config) line [aux | console | tty | vty] line-number [ending-line-number]
Router(config-line) login local
```

Vous pouvez aussi créer un utilisateur

```
username <name> secret <mdp>
```

Essayez à nouveau de vous connecter au routeur en telnet à partir de la station 192.168.0.2. La connection fonctionne-elle correctement. Essayez de passer en mode enable. Définissez un mot de passe enable si besoin (commande "enable password" sous cisco).

6.1 Routeur comme client NAS : A comme Authentification

Nous allons maintenant utiliser un modèle AAA pour assurez l'authentification en utilisant un serveur radius ainsi que l'attribution des droits et la traçabilité.

1. Activez le modèle d'authentification AAA sur le routeur.

```
Router(config) aaa new-model
```

2. Utilisez la commande "aaa authenticaion" pour créer un profil d'authentication. Il faudrait chercher et positionner la bonne méthode d'authentification. (utilisez le !).

```
Router(config) aaa authentication login {default | list-name } method1 [ method2... ]
```

3. Accédez à la configuration des lignes VTY 0 à 4.

Faites très attention, il ne faudrait pas se tromper de type de ligne, seuls les lignes VTY sont utilisées pour contrôler les connexions Telnet.

Router(config) line [aux | console | tty | vty] line-number [ending-line-number]

4. Appliquez le profil d'authentification créé aux lignes VTY.

Router(config-line) login authentication {default | list-name}

5. En utilisant la commande radius-server, configurez les paramètres de votre serveur Radius (IP, ports et secret partagé)

Router(config) radius-server

Testez maintenant différentes connexions Telenet et analysez les résultats ainsi que les messages affichés sur le serveur Radius et les messages capturées.

6.2 Routeur comme client NAS : A comme Autorisation

Dans cette section, vous allez attribuer automatiquement des droits différents aux utilisateurs suite à leur authentification.

- Commencez par modifier votre fichier users dans le serveur radius. Cisco utilise l'attribut "Service-Type" qui peut prendre les valeurs « Administrative-User » et « Login-User ». Attribuez des privilèges différents à vos utilisateurs.
- Définissez un nouveau schéma d'autorisation. Suivez les même étapes que le schéma d'authentification mais attention « authentication » devient « authorization », et que « exec » remplace « login ». Donnez un nom différent à votre liste d'autorisation.
- Appliquez le schéma crée aux lignes telnet.

Testez maintenant des connexions telnet avec les différents utilisateurs. Commentez les résultats.

6.3 Routeur comme client NAS : A comme Accounting (comptabilité)

En s'inspirant des deux sections précédentes, mettez en place un schéma de comptabilité (accounting) et appliquez le aux lignes VTY.

7 Principales références utilisées

1 Ressources pédagogiques de l'université de Pau et des pays d'Adour (TPs AAA et 802.1X).

2 Ressources pédagogiques de l'université de Rennes, Polycopié de TPs réseaux, Adlen Ksentini (TP Authentification 802.1X montée par Gilles Guette).

3 Ressources pédagogiques de l'ENSEEIHT de Toulouse, Le protocole RADIUS, Emmanuel Chaput.

4 Authentification réseau avec Radius : 802.1x - EAP - FreeRadius. Serge Bordères, Eyrolles, 2007.

5 The freeradius implementation guide, Chapter 5 - basic authentication methods, disponible en lign sur https ://networkradius.com/doc/FreeRADIUS-Implementation-Ch5.pdf